BOTIUM TOYS

Security Controls, Compliance Checklist and Risk Assessment

Beginner-level cybersecurity case study

Prepared by: **Srujana Kulkarni**

Date: **15/10/2026**

1. Scope and Goals

Scope

The scope of this assessment is the security program described in the Botium Toys case study. It includes the organization's assets, employee devices, internal network, systems, stored data, and the security controls and compliance practices described in the scenario.

Goals

Review the assets and existing controls, complete the security controls and compliance checklists, identify gaps, and recommend improvements to strengthen Botium Toys' security posture.

2. Current Assets

Asset category	Assets described in the case study
On-premises equipment	Equipment used for in-office business needs.
Employee equipment	Desktops, laptops, smartphones, remote workstations, headsets, cables, keyboards, mice, docking stations, and surveillance cameras.
Retail products	Products sold in-store and online and stored in the adjoining warehouse.
Systems, software, and services	Accounting, telecommunications, database, security, e-commerce, and inventory management.
Internet access	The organization's internet connection.
Internal network	The company's internal network.
Data retention and storage	Data stored and retained by the organization, including customer and payment-card information described in the case.
Legacy systems	End-of-life systems that require human monitoring and maintenance.

3. Risk Assessment

Risk Description

The case study describes inadequate asset management and missing or insufficient security controls. As a result, Botium Toys may not be fully aligned with applicable U.S. and international regulations and standards.

Control Best Practice: Identify

The report refers to the Identify function of the NIST Cybersecurity Framework. Botium Toys should identify and manage its assets, classify them appropriately, and consider the business impact if assets or systems are lost.

Risk Score and Potential Impact

Item	Assessment from the supplied case study
Overall risk score	8/10 — fairly high, due to gaps in security controls and compliance practices.
Potential impact of asset loss	Medium, because the organization has not fully identified which assets may be at risk.
Risk related to regulatory fines and data protection	Hig` h, because necessary controls and compliance best practices are missing or insufficient.

Note: The 8/10 score and impact ratings are taken from the supplied case study; this report does not independently recalculate them.

4. Security Controls Assessment Checklist

Statuses below reflect the narrative in the supplied case study. 'Needs improvement' means a policy or activity exists, but the scenario describes weaknesses or incomplete processes.

Control	Status	Evidence/observation from the case
Least privilege	No	Currently, all the employees have access to internally stored data and may be able to access cardholder data and customers' PII/SPII.
Disaster recovery plans	No	No disaster recovery plans currently in plan.
Password policies	Needs improvement	Password policy exists, its requirements are nominal and not in line with current minimum password complexity.
Separation of duties	No	Access controls pertaining to least privilege and separation of duties have not been implemented.
Firewall	Yes	A firewall that blocks traffic based on an appropriately defined set of security rules.
Intrusion detection system (IDS)	No	The IT department has not installed an intrusion detection system (IDS).
Backups	No	The company does not have backups of critical data.
Antivirus software	Yes	Antivirus software is installed and monitored regularly by the IT department.
Legacy system monitoring and maintenance	Needs improvement	Legacy systems are monitored and maintained, there is no regular schedule in place for these tasks and intervention methods are unclear
Encryption	No	Encryption is not currently used to ensure confidentiality of customers' credit card information that is accepted, processed, transmitted, and stored locally in the company's internal database.
Password management system	No	There is no centralized password management system that enforces the password policy's minimum requirements, which sometimes affects productivity when employees/vendors submit a ticket to the IT department to recover or reset a password.
Physical locks	Yes	The store's physical location, which includes Botium Toys' main offices, store front, and warehouse of products, has sufficient locks.
CCTV surveillance	Yes	CCTV is up-to-date.
Fire detection and prevention	Yes	Fire detection and prevention systems are well-functioning.

5. Compliance Checklist

This section reviews the practices named in the supplied checklist. It is a case-study review, not a formal certification or legal compliance determination.

5.1 PCI DSS — Payment Card Data

Best practice	Assessment	Evidence/observation
Only authorized users can access customers' credit-card information	No	Currently all the employees have access to internally stored data, including cardholder data and customer's PII/SPII
Credit-card information is handled in a secure environment	Needs improvement	Encryption is not currently used to ensure confidentiality of customers' credit card information
Data encryption procedures protect payment-card data	No	Encryption is not currently used.
Secure password management policies are adopted	Needs improvement	There is no strong and secure password management policy.

5.2 GDPR — Customer Privacy and Data

Best practice	Assessment	Evidence/observation
EU customers' data is kept private and secure	Needs improvement	The customer's data can be accessed by all the employees and encryption is not currently used for confidentiality of customer's information.
A plan exists to notify EU customers within 72 hours of a breach	Yes	The IT department has established a plan to notify E.U. customers within 72 hours if there is a security breach.
Data is properly classified and inventoried	Needs improvement	The case study describes inadequate asset management and recommends classifying assets.
Privacy policies and processes are documented and enforced	Yes	It is described that company has privacy policies and processes are documented and enforced.

5.3 SOC 1 / SOC 2 — Control Objectives

Best practice	Assessment	Evidence/observation
User access policies are established	Needs improvement	Least-privilege and separation-of-duties controls are not implemented; the case does not clearly establish whether a written access policy exists.
Sensitive data (PII/SPII) is confidential	No	The sensitive data can be accessed by all the employees and encryption is not been
Data integrity is maintained	Yes	The company has integrated controls to ensure data integrity
Data is available to authorized individuals	Yes	The company has ensured availability of data to authorized individulas.

6. Recommendations :

- Implement least privilege and strong password policies to restrict unauthorized access.

- Install and maintain firewalls, IDS, and antivirus software.
- Maintain asset inventories, regular backups, and disaster recovery plans.
- Encrypt sensitive customer and payment card data.
- Strengthen physical security using locks, CCTV, and fire prevention systems.
- Follow applicable PCI DSS and GDPR requirements to protect customer data.
- Monitor systems regularly, update software, and establish clear access policies.

7. Summary

On a scale of 1 to 10, Botium Toys has a risk score of 8, indicating a fairly high level of risk due to missing security controls and gaps in compliance practices. The organization has inadequate asset management and lacks several important security controls. The potential impact of asset loss is rated as medium because the IT department has not fully identified which assets are at risk. However, the risk of regulatory fines and data protection issues is high because some required security controls and compliance best practices are not in place.

8. Conclusion

Botium Toys should prioritize the identified security gaps while maintaining the controls that are already in place. Improving access control, protecting sensitive data, establishing backups and recovery plans, strengthening asset management, and improving monitoring would help reduce risk and protect customer information.